

EN 304 623: Boot Managers

Deep Dive Session

https://docbox.etsi.org/CYBER/EUSR/Open/EN-304-623_V0.0.12_2025-12-19_Boot_Managers_Mature-draft.pdf



Agenda

- Boot managers and the CRA
- EN 304 623 structure and scope
- Product description, risk, requirements
- Conformity assessment
- Timeline and open questions



Why Boot Managers matter?

- **Privileged Position:** Executes at highest privilege level with direct hardware access before any OS or security tools load
- **Persistence:** Survives OS reinstallation and traditional security remediation. Firmware-level compromise is notoriously difficult to detect and remove.
- **Invisibility:** Operates below OS visibility. Antivirus and EDR cannot observe boot-level activity.
- **Trust Foundation:** Forms the root of all subsequent security decisions. If boot is compromised, nothing above it can be trusted.

// Real-world examples

LoJax (2018)

UEFI rootkit

MosaicRegressor (2020)

Firmware implant

BlackLotus (2023)

Secure Boot bypass

LogoFAIL (2023)

Image parser exploit

PixieFAIL (2024)

PXE vulnerabilities

2024/2847

20.11.2024

REGULATION (EU) 2024/2847 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL

of 23 October 2024

on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)

(Text with EEA relevance)

2025/2392

1.12.2025

COMMISSION IMPLEMENTING REGULATION (EU) 2025/2392

of 28 November 2025

on the technical description of the categories of important and critical products with digital elements pursuant to Regulation (EU) 2024/2847 of the European Parliament and of the Council

(Text with EEA relevance)

COMMISSION IMPLEMENTING DECISION

of 3.2.2025

on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)

(only the English, French and German texts are authentic)

The CRA and Boot Managers

CRA Regulation (EU) 2024/2847 defines Boot Managers as **Class I Important Products** (Annex III)

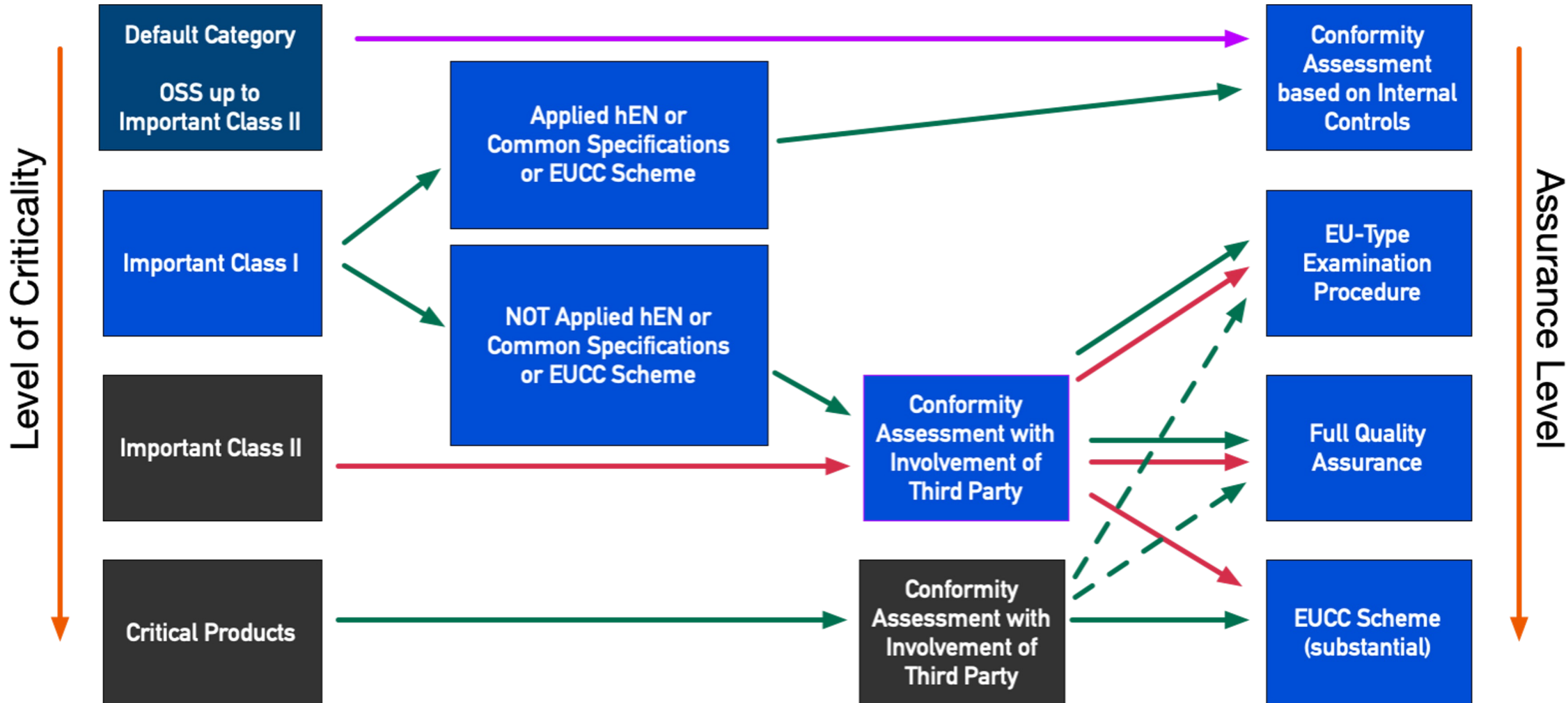
Technical description: Implementing Regulation (EU) 2025/2392 “Technical description of the categories of important and critical products”, Annex I:

Software products with digital elements that manage the process of initial system startup after power on/restart by initialising hardware, loading or transferring control to the operating system environment or system resources, and selecting boot options. This category includes but is not limited to UEFI firmware, single-stage and multi-stage boot loaders.

Standardisation Request M/606 by European Commission: Implementing Decision, Annex, line item 23: “*European standard(s) on essential cybersecurity requirements for boot managers*”

ETSI Work Item: DEN/CYBER-EUS-008

CRA Conformity Assessment



by Jose Emilio Rico, DEKRA (with modifications)



EN 304 623 Structure

Main clauses

- Clause 1: Scope
- Clause 2: Normative and informative references
- Clause 3: Terms and definitions
- Clause 4: Product description (architecture, capabilities, environment, risks)
- Clause 5 (normative): Requirements (10 categories, 92 requirements)
- Clause 6: Conformity assessment (8 grouped evaluation activities)

Annexes

- Annex A (normative): CRA essential requirements mapping
- Annex B: Threat catalogue, STRIDE-based, CVE-informed
- Annex C: Product documentation
- Annex D: Vulnerability handling considerations
- Annex E: NIST 800-193 mapping
- Annex F: Assessment guidance

In preparation

- Annex K (normative): Accepted Cryptographic Methods (ACM)

EN 304 623: Scope

Software and firmware regardless of distribution model or integration level, maybe single- or multi-stage:

- System firmware (hardware init + boot management)
- Bootloaders (target selection, verification, and loading)
- Embedded boot firmware (IoT and embedded devices)
- Network boot implementations
- Boot managers with hardware security components

For MCUs and MPUs

- Silicon integrated immutable firmware
- Updateable boot managers

Runtime services

- Only if they provide verification or attestation services to the boot process (not boot target)





EN 304 623

Boot Architectures

Unverified boot

- Sequential execution without cryptographic verification
- May include CRC/checksum for corruption detection

Verified Boot

- Cryptographic verification before execution
- Failure blocks boot or triggers recovery

Measured Boot

- Records measurements without blocking
- Enables attestation, boot continues regardless of values

Key difference

- Verified: Enforcement - blocks execution on failure
- Measured: Attestation - records for later verification

Systems may implement both.

EN 304 623

Product Capabilities

Capability	Values
Updates	No updates, configuration updates, partial updates, full updates, runtime updates, recovery mode updates, network updates, enclave managed updates
Boot source	Internal storage, fixed storage, removable storage, network boot, external expansion, debug interfaces
Configuration management	No configuration, static configuration, local configuration, protected configuration, remote configuration, runtime configuration
Hardware security	Software only, hardware storage, hardware enforcement
Recovery	No recovery, basic recovery, full recovery
Authentication	No authentication, physical presence, password authentication, cryptographic authentication, multi factor authentication
Logging	No logging, volatile logging, persistent logging, hardware protected logging, external logging
Debug interface	No debug interface, disabled debug: Debug interfaces physically, authenticated debug, conditional debug, open debug



EN 304 623

Operational Environment

Factor	Values
Physical security	Secure, controlled, restricted, public, hostile, mobile
Network exposure	Air-gapped, isolated, managed, internet, cellular
Data sensitivity	Minimal, personal, financial, health, business, critical
System criticality	Non-critical, business impact , safety-critical
Lifecycle expectations	Short (<5y), medium (5-15y), long >15y
Administrative control	Centrally managed, user, vendor, hybrid, autonomous
Availability requirements	Flexible, standard, high, critical

Deployment context is independent of product capabilities. Same boot manager in different environments = different risk profiles.

EN 304 623 Assets

Asset	
A-CRYPT	Cryptographic keys and certificates
A-ROLLBACK	Rollback protection data (version counters)
A-CONFIG	Configuration data (security policy, trust anchors)
A-AUTH	Authentication credentials
A-MEASURE	Measurement and attestation data
A-AUDIT	Audit logs
A-CODE	Boot manager executable code
A-UPDATE	Update packages and delivery mechanisms
A-RUNTIME	Runtime state data

Boot managers protect critical assets that, if compromised, undermine system security..





EN 304 623 Threats

Threat	Examples
T-INTEGRITY	Boot integrity attacks (code execution, config tampering, rollback)
T-PERSIST	Persistent firmware threats (implants, bootkits, SPI flash modification)
T-PHYS	Physical attacks (debug abuse, bus interception, evil maid)
T-SUPPLY	Supply chain attacks (compromised updates, key leakage)
T-NET	Network-based attacks (PXE exploits, rogue boot servers)
T-AVAIL	Availability threats (boot loops, bricking, recovery bypass)

Six threat categories derived from STRIDE methodology and real-world CVEs (see Annex B).



EN 304 623

Risk-Based Approach

Requirements apply based on risk level determined by 6 factors.

Impact factors

- **RF-SAFE:** Safety and infrastructure (0-3)
- **RF-DATA:** Data sensitivity (0-3)

Likelihood factors

- **RF-ATK:** Attacker motivation (1-3)
- **RF-NET:** Network exposure (1-3)
- **RF-PHYS:** Physical accessibility (1-3)
- **RF-PATCH:** Remediation capability (1-3)

Risk level determination

- **HIGH:** Impact=3, or Impact $\geq$ 2 with any likelihood=3
- **MEDIUM:** Impact=2, or likelihood sum $\geq$ 8
- **LOW:** Otherwise

Representative Use Cases

UC	Name	Risk	Examples
L1	Immutable embedded	LOW	Sensors, ROM-based MCUs, toys
L2	Updateable IoT/consumer	LOW	Smart TVs, smart home, appliances
M1	Consumer/SMB computing	MEDIUM	Laptops, desktops, smartphones, NAS
M2	Enterprise managed	MEDIUM	Workstations, servers, virtualization
H1	Critical systems	HIGH	Medical, industrial, financial, telecom

Use cases are illustrative, not normative product categories.
Manufacturers select closest match, then assess risk factors.

EN 304 623 Requirements Overview

Category	#	Key topics
Security by Design	5	Isolation, separation, handoff
Secure by Default	6	Restrictive defaults, debug disabled
Authentication	7	Physical presence, credential protection
Confidentiality	8	Key separation, secure disposal
Integrity	23	Chain of trust, verification, anti-rollback
Data Minimization	3	Minimal collection and retention
Availability	18	Recovery, redundancy, resilience
Impact/Attack Surface	8	Limit blast radius, minimize features
Logging	5	Measurements, attestation, events
Vulnerability Handling	9	SBOM, updates, CVD, support period

92 requirements across 10 categories, with applicability based on risk level and capabilities.





EN 304 623 Examples

ID	Requirement	Applies to
RQ-SBD-001	Isolate boot components using memory protection, privilege separation, or hardware isolation	All
RQ-DEFAULT-001	Ship with most restrictive security settings enabled	All
RQ-INTEGRITY-002	Prevent boot continuation with components that fail verification	Verified boot
RQ-INTEGRITY-009	Require authentication before modifying verification policy	MEDIUM/HIGH + Config capability
RQ-AUTH-003	Require explicit user action and authentication before security-critical config changes	Config capability
RQ-AVAIL-003	Enforce timeouts to prevent indefinite blocking	All

Requirements specify what to achieve and when they apply - examples show the pattern.

EN 304 623 Conformity Assessment

Co-funded by



Co-funded by
the European Union



Assessment Group	Area
EA-BM-DESIGN	Secure design
EA-BM-DEFAULT	Secure defaults
EA-BM-AUTH	Authentication and access control
EA-BM-CONFID	Confidentiality
EA-BM-INTEGRITY	Integrity protection
EA-BM-AVAIL	Availability and resilience
EA-BM-LOG	Logging and measurement
EA-BM-VULN	Vulnerability handling

Assessment depth by risk

- **LOW:** Doc review + functional test
- **MEDIUM:** + mechanism testing, failure modes
- **HIGH:** + resistance testing, bypass attempts





EN 304 623 Annexes

Annex	Type	Content
A	Normative	CRA Annex I mapping (establishes presumption of conformity)
B	Informative	Threat catalogue (STRIDE-based, CVE-informed)
C	Informative	Product documentation templates
D	Informative	Vulnerability handling considerations
E	Informative	NIST SP 800-193 mapping (Platform Firmware Resiliency)
F	Informative	Assessment guidance
K	Normative	Accepted Cryptographic Methods (ACM) in preparation

Annexes provide mapping to CRA requirements, threat analysis, and implementation guidance.

EN 304 623 From Product to Conformity

Step	Action	Clause
1	Is my product in scope?	1.2
2	Describe architecture and capabilities	4.3
3	Document operational environment	4.4
4	Assess 6 risk factors	4.7.8
5	Determine risk level (LOW/MEDIUM/HIGH)	4.7.8.3
6	Identify applicable requirements	5
7	Prepare evidence	Annex C
8	Pass evaluation criteria	6

Result: Presumption of conformity with CRA Annex I (via Annex A mapping)





EN 304 623 Timeline

Date	Milestone
Dec 2024	CRA entered into force
Feb 2026	Feedback HAS review
Now	Mature Draft v0.0.12
Q1 2026	WG review and refinement
Q2 2026	Public ENQ
Sep 2026	CRA reporting obligations apply
Oct 2026	ESO deadline Type C standards M/606
Dec 2027	CRA full application

Open Questions: what is not yet decided, what is still to do?

- Annex K (ACM): Accepted Cryptographic Methods, in preparation
- Alignment with horizontal standards (prEN 40000-1-x)
- Vulnerability handling
- Doesn't address CRA attestation for open-source software
- Improve documentation templates
- Missing details on conformity assessment
- Waiting for the results of the first HAS assessment



Q&A





Thank you for your attention



Co-funded by
the European Union

Follow us on:

